

VULNERABILITY ASSESSMENT & PENETRATION TESTING

Technical Security Assessment Report

Target System:	https://example.com	Assessment Date:	August 15 – 20, 2026
Assessment Type:	Gray-Box Web Application VAPT	Overall Risk Rating:	HIGH
Methodology:	OWASP WSTG v4.2	Prepared By:	Cybersecurity Audit Team

1. EXECUTIVE SUMMARY

During the technical security assessment conducted on **https://example.com**, a total of **4 vulnerabilities** were identified across the web application and server configuration. The overall risk profile of the application is rated as **HIGH**, primarily due to an input validation flaw resulting in Reflected Cross-Site Scripting (XSS). Immediate remediation is recommended to mitigate risk to client sessions and data integrity.

2. VULNERABILITY SEVERITY SUMMARY

Severity Level	Count	Status	Risk Summary
CRITICAL	0	—	No critical vulnerabilities identified.
HIGH	1	Open	Requires immediate attention; potential session compromise.
MEDIUM	1	Open	Requires planned remediation; missing core browser defenses.
LOW	1	Open	Low exploitability; outdated cryptographic protocols.
INFORMATIONAL	1	Open	Informational disclosure; configuration hardening suggested.

3. DETAILED FINDINGS & REMEDIATION

Finding #1: Reflected Cross-Site Scripting (XSS)

Severity: **HIGH** CVSS v3.1 Score: 7.5 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:L/A:N)

Affected Endpoint: <https://example.com/search?query=>

Description: The search feature fails to validate or sanitize user input before reflecting it back in the HTTP response body. An attacker can craft a malicious URL containing JavaScript payloads that execute in the context of the user's browser session.

Remediation: Implement context-aware HTML entity encoding on all user-supplied data prior to rendering it within HTML documents. Utilize secure frameworks or encoding libraries.

Finding #2: Missing HTTP Security Headers

Severity: **MEDIUM**

CVSS v3.1 Score: 5.4 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N)

Affected Target: Web Server Configuration

Description: The application does not enforce browser-side security measures due to missing HTTP response headers, including Content-Security-Policy (CSP) and Strict-Transport-Security (HSTS).

Remediation: Configure the web server to send standard security headers with all HTTP responses:

- Strict-Transport-Security: max-age=31536000; includeSubDomains
- Content-Security-Policy: default-src 'self'; script-src 'self';

Finding #3: Weak TLS Protocol Support (TLS 1.0 / 1.1)

Severity: **LOW**

CVSS v3.1 Score: 3.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)

Affected Service: Port 443/TCP (HTTPS)

Description: The web server negotiates SSL/TLS connections using legacy TLS 1.0 and TLS 1.1 protocols, which have known security weaknesses and are deprecated by industry standards.

Remediation: Disable support for TLS 1.0 and TLS 1.1 on web server SSL configurations. Enforce TLS 1.2 and TLS 1.3 only.

Finding #4: Server Version Disclosure

Severity: **INFO**

CVSS v3.1 Score: 0.0

Affected Header: `Server: Apache/2.4.41 (Ubuntu)`

Description: The HTTP response header exposes exact web server software and operating system version details, which helps malicious actors perform targeted reconnaissance.

Remediation: Modify server configuration to minimize or suppress version banners (e.g., set ServerTokens Prod in Apache configuration).